MEDX HEALTH PLATFORM

Technical Solution Design

Telehealth consultations · Patient records · Prescription tracking

High-level architecture · component design · data & storage · scalability & performance · security & compliance



Mini-project 5DESI · Architecture proposal · 2026

DESIGN DRIVERS

What MedX needs — and what comes first

MEDX MISSION

Telehealth consultations

Book, meet a doctor by video, chat and share documents

Patient records

A lifelong, trustworthy record — available in emergencies

Prescription tracking

From the doctor's signature to the pharmacy counter

H HIGH *Non-negotiable foundations*

- Encryption at rest & in transit
- Patient records management
- Emergency access
- Authentication & authorization
- Integrity & secure files

M MEDIUM *Care workflows*

- Scheduling
- Video · chat · files
- Prescriptions
- Masking & redaction
- External calendars

L LOW *Designed now, delivered last*

- Pharmacy interface
- Preferences
- Notification tracking
- Anonymization
- Payments
- Refunds

High priorities become architecture principles · Medium features are built on them · Low features are designed now, delivered last

DESIGN TARGETS & PRINCIPLES

Sized for 10× growth, guided by eight principles

10 M	200 k	10 k	99.99 %	< 300 ms
registered patients (Year 3)	teleconsultations per day	concurrent video calls at peak	availability of emergency access	to serve a critical summary

P1

Privacy by design

Encrypt everything, minimise, deny by default

P2

Patient safety first

The emergency path works when all else fails

P3

Integrity first

Clinical history is never rewritten

P4

Standards over custom

FHIR · OpenID Connect · WebRTC · OpenAPI

P5

Loose coupling

Domain events, one database per service

P6

Reuse, then build

Reuse IdP, PSP, SFU — build care logic

P7

Scale out & automate

Stateless, autoscaled, infrastructure as code

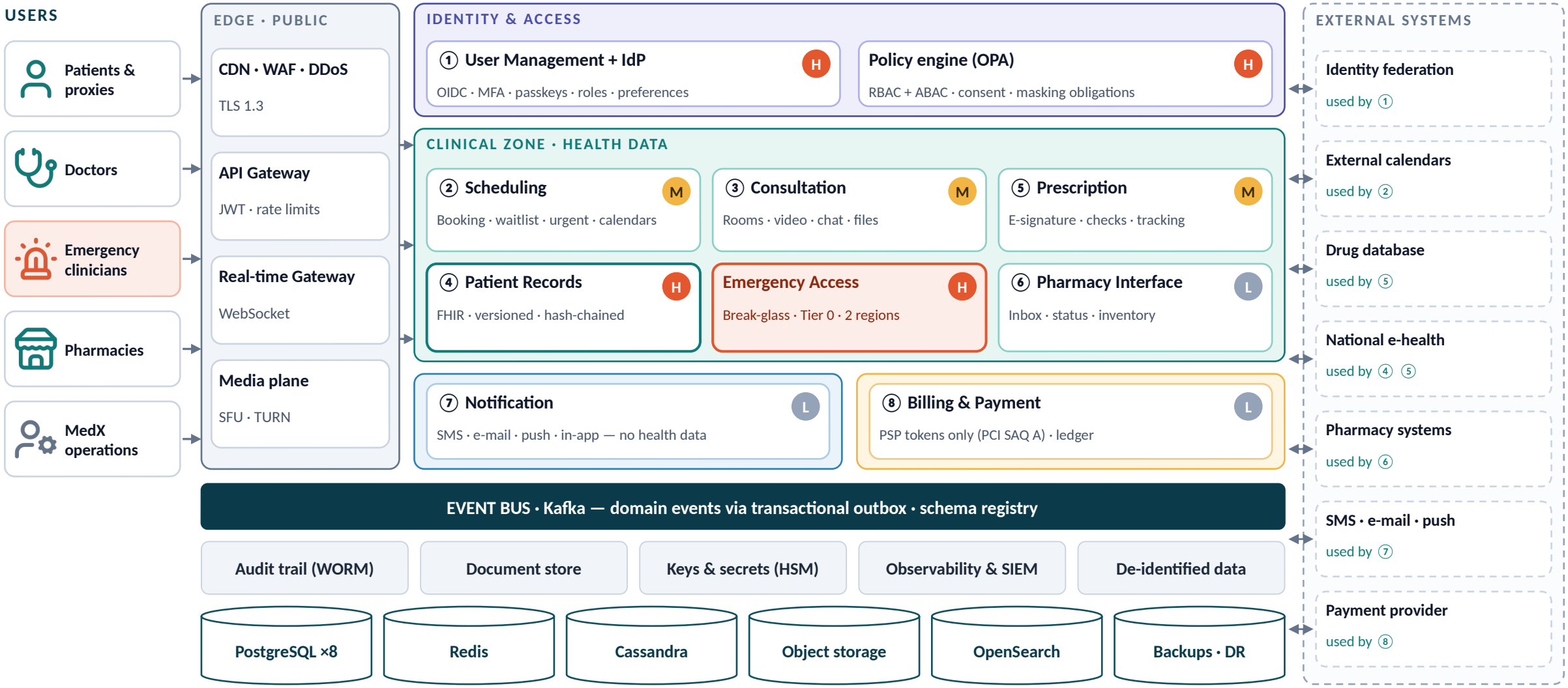
P8

Observable & auditable

Every request traced, every access audited

HIGH-LEVEL ARCHITECTURE

Architecture at a glance



ARCHITECTURE LOGIC

One care journey across the services

1

Book

② Scheduling · ⑧ Billing

10-min slot hold + database exclusion constraint · fee pre-authorised

2

Consult

③ Consultation

Waiting room · WebRTC SFU · end-to-end encryption · chat & files

3

Document

④ Patient Records

FHIR note, signed · versioned · hash-chained · audited

4

Prescribe

⑤ Prescription

Allergy & interaction checks · e-signature in HSM · QR verification

5

Dispense & pay

⑥ Pharmacy · ⑧ Billing · ⑦

Pharmacy statuses · payment captured · invoice · patient notified

Kafka events: AppointmentBooked → ConsultationCompleted → RecordUpdated → PrescriptionIssued → FulfilmentStatusUpdated · PaymentCaptured

Synchronous only when a user waits

At most 2 hops, timeouts and circuit breakers everywhere

Events carry IDs, never clinical data

Consumers fetch details under their own authorization

Transactional outbox

No lost or phantom events · idempotent consumers

HIGH PRIORITY · H4

Strong identity, fine-grained authorization

KEYCLOAK — 3 REALMS, 3 RISK PROFILES

Patients

Passkey or password · risk-based MFA · biometric unlock on mobile · DPoP-bound 10-min tokens

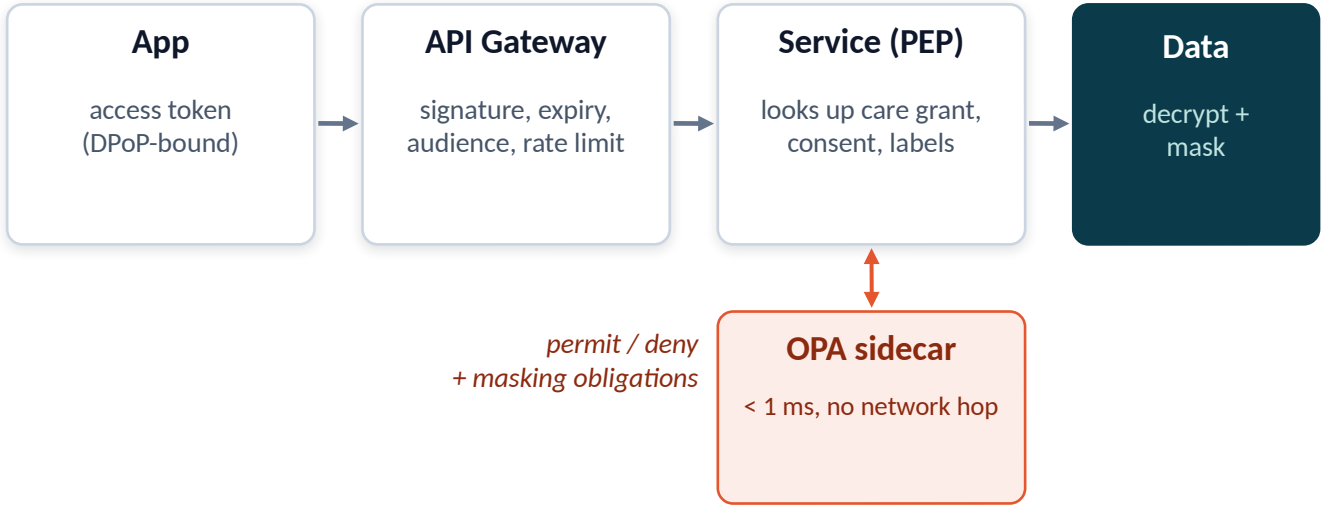
Professionals

Phishing-resistant MFA always (passkey, e-CPS smart card) · step-up before signing or break-glass · 15-min idle timeout

MedX workforce

Corporate SSO + hardware keys · just-in-time admin, recorded · no access to health data

EVERY REQUEST ON HEALTH DATA



RBAC + ABAC decision

Role doctor + Relationship care grant + Purpose treatment + Consent labels + Assurance MFA level

Policies as code: Git → unit tests → signed bundles → sidecars. Deny by default.

HIGH PRIORITY · H2 · H5

Patient records: complete, correct, tamper-evident

EVERY REQUEST CROSSES THE SAME CHAIN

1. Authorization (PEP → OPA)
2. Validation (FHIR profiles)
3. Provenance (who, why)
4. Encryption (patient key)
5. Hash chain
6. Audit (same transaction)
7. Masking (obligations)

FHIR R4 + International Patient Summary

Standard model with validation, versioning and search — ready for national services and hospitals.

History is never rewritten

Append-only versions · signed notes, then addenda · "entered-in-error" instead of delete.

Tamper-evident

Per-patient hash chain · daily Merkle root signed in HSM, timestamped, stored write-once.

Right person, right reason

Self · proxy · care grant (30 days) · patient share · break-glass. Pharmacists and staff: no access.

MASKING & REDACTION (M4)

Support agent: +33 6 •• •• •• 42 · Pharmacist: no diagnosis · Break-glass: psychotherapy notes excluded · Patient: results released after review · Logs: never any PHI

HIGH PRIORITY · H3

Emergency access in seconds — accountable afterwards

1 Identify

Exact match only: national ID, or name + birth date + sex

2 Declare

Reason code + free-text justification

3 Step-up MFA

Passkey or smart card · entitlement & opt-out checked

4 Time-boxed grant

4 hours · read-only · this patient only

5 Summary < 1 s

Allergies, problems, medications, blood group, directives

≈ 30 s for the clinician · p95 < 300 ms per API call · 99.99 % availability · active in two regions

Guardrails — accountable afterwards

- Audit event written in the same transaction as the grant
- Real-time alert to the privacy office (SIEM)
- Patient informed within 24 h: who, when, what
- Mandatory review within 72 h; misuse → suspension
- Patients may opt out where the law allows it

Tier 0 — survives failures

- Separate deployment with reserved capacity (bulkhead)
- Pre-computed summary read from local replicas
- Active in the DR region with its own grant database
- Token and policy checks are local (cached keys, OPA)
- Audit buffered in an outbox if the pipeline is down

HIGH PRIORITY · H1 · H5

Encrypted everywhere, integrity you can prove

In transit

Apps ↔ edge

TLS 1.3 · HSTS · pinning · hybrid post-quantum

Service ↔ service

mTLS in the mesh, STRICT mode

Service ↔ data

TLS verify-full, short-lived credentials

Video & audio

DTLS-SRTP + end-to-end (SFrame)

Partners

mTLS + OAuth 2.0 · signed webhooks

At rest — envelope encryption

HSM root keys

FIPS 140-3 level 3 · never exported

↓

KEK per service · env · class

in KMS · rotated yearly · every use logged

↓

Data key per patient / file / chat

AES-256-GCM · cached ≤ 5 min in memory

↓

Ciphertext + storage encryption

two independent layers

Crypto-shredding: destroy a patient's keys at end of retention → every copy unreadable

Integrity

- ACID transactions, constraints, optimistic concurrency
- Append-only history + per-patient hash chains
- Daily signed anchors in write-once storage
- SHA-256 on every file · scanned uploads
- Immutable cross-account backups · weekly restore tests

MEDIUM PRIORITY · M1 – M5

Care workflows built on the secure core

Scheduling & calendars

M1 · M5

- 10-min slot hold + database exclusion constraint → no double booking
- Waitlist offers and an urgent queue for on-call doctors; red flags → call 15 / 112
- Doctors notified live (WebSocket + push)
- Google · Microsoft · CalDAV: free/busy only, no patient data written

KEY MECHANISM

A PostgreSQL exclusion constraint on (doctor, time range) makes overlapping bookings physically impossible.

Consultation

M2

- Waiting room, short-lived room tokens
- Self-hosted WebRTC SFU in the EU + TURN on port 443
- Simulcast, audio-only fallback, auto-reconnect
- End-to-end encryption for 1-to-1 · no recording
- Chat with receipts · files scanned & encrypted

KEY MECHANISM

Control plane (rooms, tokens) is separated from the media plane (SFU): media never touches business services.

Prescription & masking

M3 · M4

- Allergy & interaction checks at signing
- E-signature in HSM · QR code for pharmacy verification
- Modify = new signed version; revoke = critical alert to the pharmacy
- Pharmacists see only what dispensing requires

KEY MECHANISM

Two state machines — legal status (prescriber) and fulfilment (pharmacy): never "ready" on a revoked prescription.

LOW PRIORITY · L1 – L6

Ecosystem services — designed now, delivered last

Pharmacy interface

L1

- Portal for every pharmacy + partner API with signed webhooks
- Statuses: received → ready → dispensed
- Inventory adapters, nearby availability

Until then: printable prescription with a verifiable QR code, usable in any pharmacy

Notifications

L2 · L3

- SMS · e-mail · push · in-app, with priority lanes
- Preferences, quiet hours, frequency caps
- Delivery & read tracking — no health data in messages

A thin transactional version (confirmations, reminders) ships with the Medium features

Billing & refunds

L5 · L6

- PSP hosted fields → PCI DSS SAQ A
- Pre-authorise at booking, capture after
- Ledger, invoices, credit notes, 4-eyes refunds

Bought, not built: the payment provider carries card data and fraud checks

Anonymization

L4

- Synthetic patients for dev, staging, demo
- Anonymisation pipeline with k-anonymity
- DPO approval · production keys unusable elsewhere

Rule from day one: production health data never leaves production

PostgreSQL by default, specialised stores only when justified

Component	System of record	Also uses	Why
① **User Management**	PostgreSQL	Redis (sessions)	Identities; e-mail encrypted with blind index
② **Scheduling**	PostgreSQL	Redis · OpenSearch	Exclusion constraint: no double booking
③ **Consultation**	PostgreSQL	Cassandra (chat, 30 d)	Append-heavy chat with expiry
④ **Patient Records**	PostgreSQL (FHIR JSONB)	Replicas ×3 + DR	ACID, versions, hash chain · ~10 TB
⑤ **Prescription**	PostgreSQL	OpenSearch (drugs)	Signed, immutable versions
⑥ **Pharmacy**	PostgreSQL + PostGIS	Redis (availability)	Geo search, status events
⑦ **Notification**	Cassandra	PostgreSQL · Redis	Write-heavy log, 13-month TTL
⑧ **Billing**	PostgreSQL	Object storage (PDF)	Double-entry, append-only ledger
Documents	Object storage	PostgreSQL (metadata)	~150 TB · versioning · Object Lock
Audit trail	Object storage (WORM)	OpenSearch · SIEM	Tamper-evident archive

PRINCIPLES

- One database per service; references by ID only
- Classify first: C0 public → C4 sensitive health data
- Clinical, legal and financial data are append-only
- Caches and indexes are rebuildable, never the only copy
- Record kept 20 years, then crypto-shredded
- Everything encrypted, private, backed up, monitored

SCALABILITY & PERFORMANCE

Built for 10× growth, tested at 2× peak

5 k → 10 k	10 k	24 Gbit/s	150 TB
API req/s at peak → design capacity	concurrent video calls ≈ 100 SFU nodes	media egress at Year-3 peak	documents in object storage

Autoscale on the real bottleneck
RPS, connections, queue lag, participants

Pre-compute the hot paths
Availability, emergency summaries

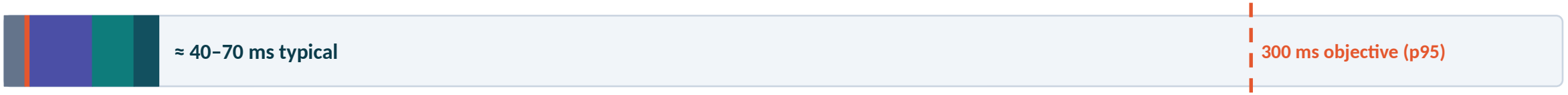
Absorb peaks with Kafka
Priority lanes for notifications

Replicas → partitions → shards
Records sharded by patient when triggered

Adaptive video
Simulcast, audio-first, drain on scale-in

Regional cells
Isolated copies per country / population

EMERGENCY PATH LATENCY BUDGET (server side)

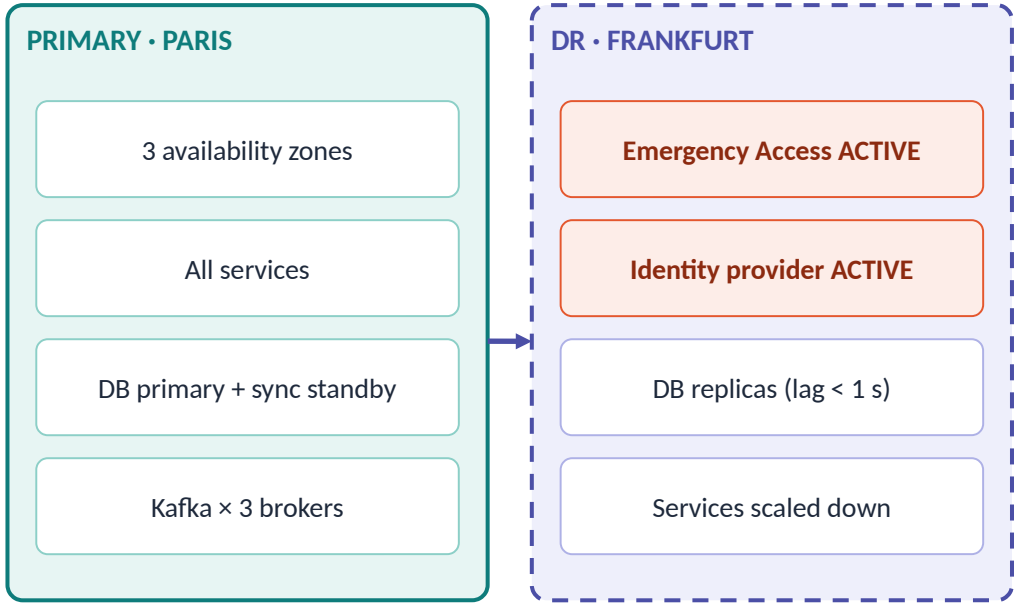


Gateway 5 ms · policy < 1 ms · grant + audit 15 ms · summary read 10 ms · key + decrypt 6 ms — large margin for network jitter and failover

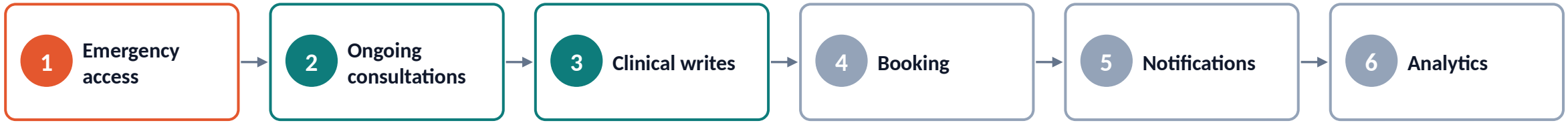
Load, soak, chaos and WebRTC tests at 2× forecast peak before every major release · SLOs with error budgets

Resilient by tier — emergency access survives a region loss

Tier	Scope	Availability	RPO	RTO (region loss)
Tier 0	Emergency access, sign-in, record reads	**99.99 %**	0 in-region · ≤ 1 min	≤ 15 min · active in both regions
Tier 1	Records writes, consultation, scheduling, prescription	**99.95 %**	0 in-region · ≤ 1 min	≤ 1 h
Tier 2	Pharmacy, notification, billing, analytics	**99.9 %**	≤ 5 min	≤ 4 h



LOAD-SHEDDING ORDER UNDER EXTREME LOAD (protected first → shed first)



SECURITY & COMPLIANCE

Compliance by design, not by audit

GDPR

Health data (art. 9) · DPIA · DPO · 72-h breach notice

HDS

Certified hosting · data stays in the EEA

Telemedicine rules

Identified patient, consent, report in the record

NIS2

Risk measures · incident reports 24 h / 72 h

eIDAS

Prescription signatures · qualified timestamps

PCI DSS

SAQ A: card data only at the PSP

EHDS

Patient access & exchange · access logging

HIPAA-ready

Separate US cell, same controls, BAAs

Privacy by design

- No health data in SMS, e-mail, push, calendars, events or logs
- Production data never leaves production — synthetic data elsewhere
- 20-year retention, then crypto-shredding
- Patients see who accessed their record
- STRIDE threat model: 15 top threats mitigated
- Pentest before launch, then yearly; ISO 27001 in year 1–2

DECISIONS & TRADE-OFFS

What we chose — and what we accepted to give up

We chose	Instead of	Because	Cost we accept
Microservices in security zones	Modular monolith	H1 · H3	Operational complexity
Break-glass + post-hoc review	Supervisor pre-approval	H3	Possible misuse — detected & sanctioned
Per-patient envelope encryption	Disk encryption only	H1	Key management, ~1 ms per request
Append-only history + hash chains	In-place updates	H2 · H5	~30 % more storage
Self-hosted SFU + end-to-end encryption	Video CPaaS	H1 · M2	Media operations, no recording
Active-active for Tier 0 only	Full active-active	H3	Tier 1–2 recover in 1–4 h
PSP hosted payment fields	Handling card data	L5	Less control over payment UI

Full decision records (14 ADRs) with context, alternatives and consequences: docs/06-architecture-decisions.md

ROADMAP

Delivered in the order of MedX priorities

Phase 0

Foundations

≈ 2 months

- Landing zone, Kubernetes, mesh
- KMS/HSM, Vault, audit, Kafka
- CI/CD with signed images

Exit: all built from code, 100 % of stores encrypted

Phase 1

Secure clinical core

HIGH · ≈ 4 months

- Identity, OPA policies
- Records, integrity, encryption
- Emergency access + DR region

Exit: authz tests green, break-glass < 300 ms, DR drill

Gate: DPIA · pentest · DR drill

Phase 2

Care workflows

MEDIUM · ≈ 4 months

- Scheduling + calendars
- Video, chat, files
- Prescriptions + masking

Exit: load test at 2× peak, video quality KPIs met

Pilot with partner clinics

Phase 3

Ecosystem

LOW · ≈ 4 months

- Pharmacy interface
- Notifications, preferences
- Billing, refunds, anonymisation

Exit: PCI SAQ A attested, ledger reconciled

Public launch

Phase 4

Scale & expand

continuous

- National e-health services
- Sharding, regional cells
- ISO 27001, US cell

Triggered by measured growth and new markets

IN SUMMARY

A zero-trust, event-driven platform where health data is encrypted twice, history cannot be rewritten, and emergency access works in seconds.

Security is the foundation

TLS 1.3 / mTLS everywhere · per-patient keys in HSM · RBAC + ABAC · immutable audit

Emergency access in seconds

Break-glass on an isolated Tier-0 path, active in two regions, reviewed within 72 h

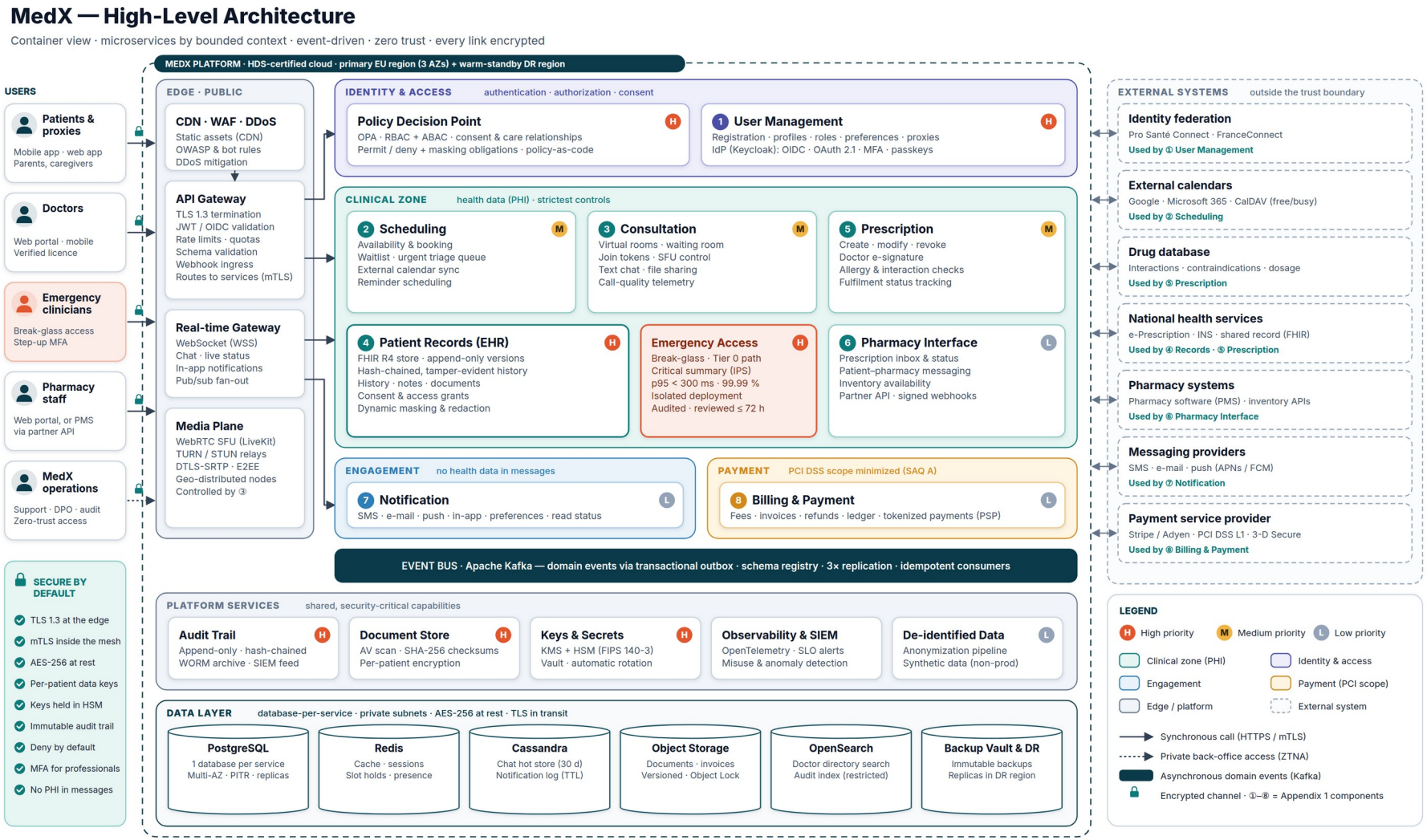
Scales by design

Events, autoscaling, replicas → shards → cells · tested at 2× peak

Questions?

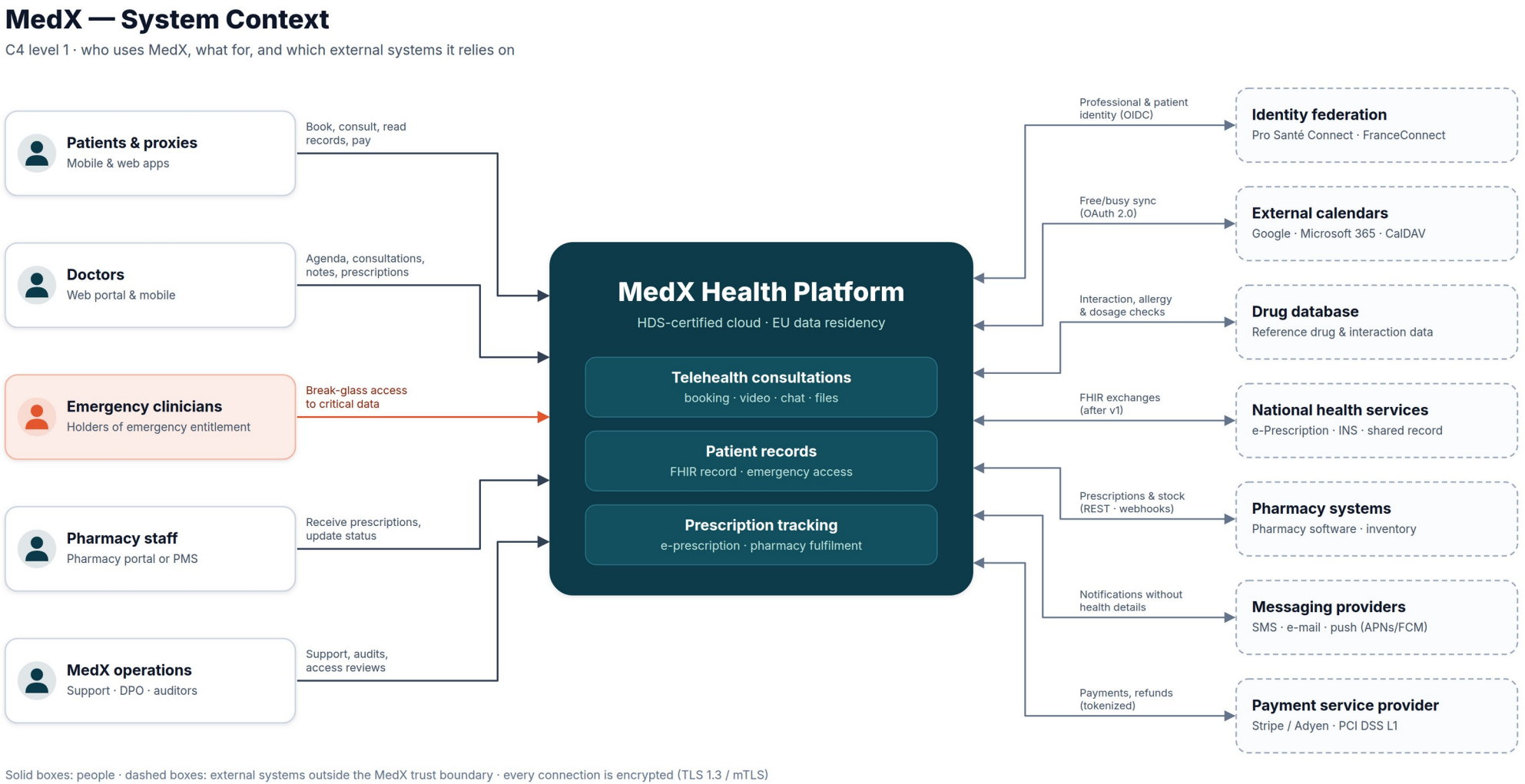
Full design package: docs/ · diagrams/ · presentation/

Detailed high-level architecture



APPENDIX A2

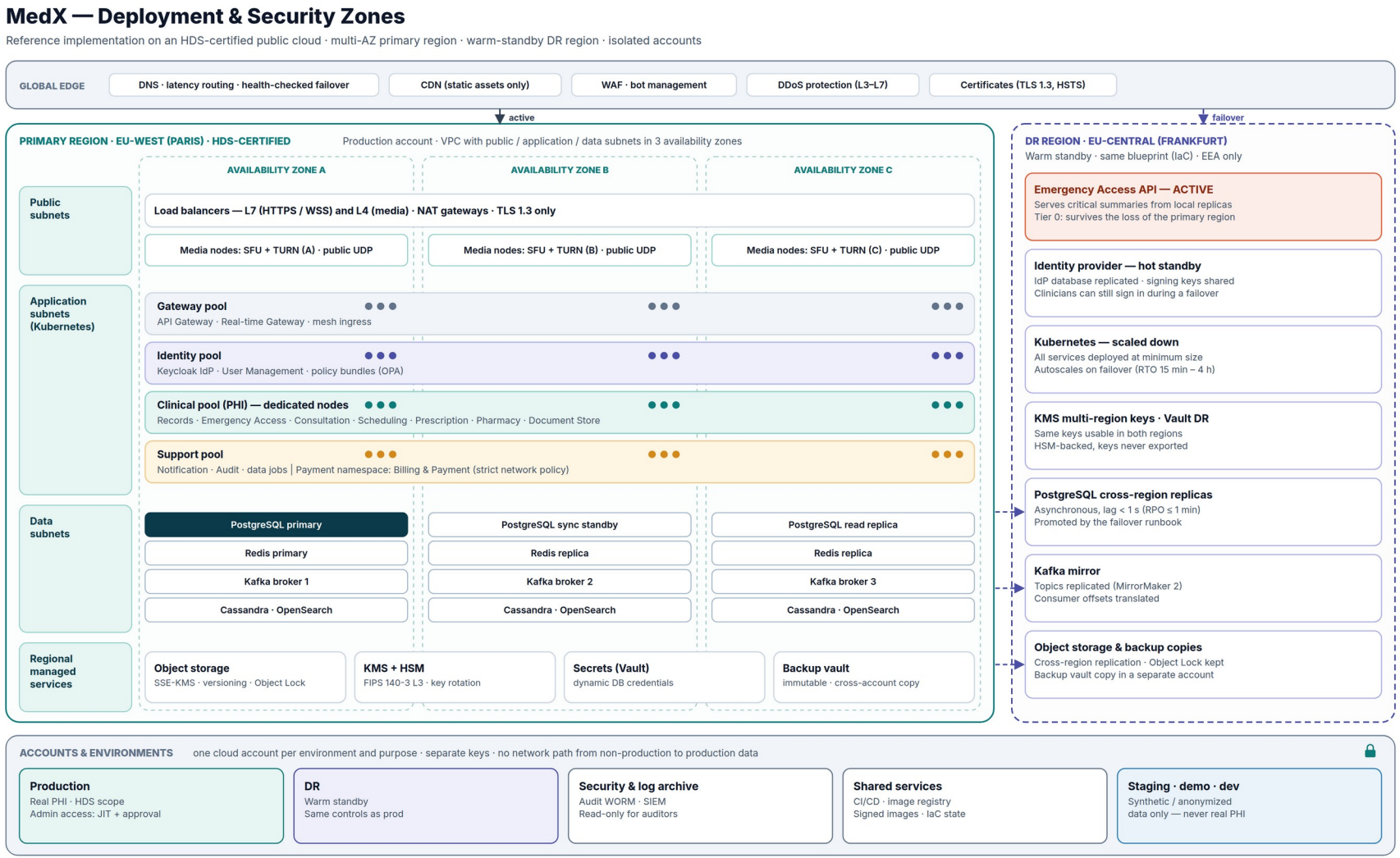
System context (C4 level 1)



Solid boxes: people · dashed boxes: external systems outside the MedX trust boundary · every connection is encrypted (TLS 1.3 / mTLS)

APPENDIX A3

Deployment & security zones



Emergency access — detailed flow

Emergency Access (Break-Glass)

High-priority requirement H3 · immediate access to critical data for authorized professionals, with full accountability afterwards

1 Identify the patient

Exact-match search only:
INS / MedX ID, or name + birth date + sex
Minimal demographics to confirm identity
No browsing, no wildcards

→

2 Declare emergency

Reason code (unconscious, life-threatening, unable to consent…)
Free-text justification
Accountability statement "I will be audited"

→

3 Step-up MFA

Passkey or smart card (e-CPS) in the last 15 min
Policy engine checks the emergency_access entitlement and the patient's opt-out

→

4 Time-boxed grant

4 hours · read-only
This patient only
Grant + audit event written in the same transaction
Renewable with a new reason

→

5 Summary in < 1 s

International Patient Summary: allergies, active problems, medications, blood group, implants, advance directives, contacts
Full record: same grant

Clinician: ≈ 30 seconds from search to data (human steps) · System: p95 < 300 ms per API call · Availability 99.99 %

GUARDRAILS — ACCOUNTABILITY AFTER THE FACT (access is never blocked, always answered for)

Immutable audit
AuditEvent, purpose = emergency treatment, kept in the WORM trail

Real-time alert
Privacy office alerted through the SIEM the moment access starts

Patient informed
In-app + e-mail notice within 24 h: who, when, what was viewed

Mandatory review
Privacy officer + medical lead review every case within 72 h

Misuse detection
Behaviour analytics flag outliers; sanctions and account suspension

RESILIENCE — WHY THE TIER-0 PATH KEEPS WORKING WHEN OTHER SERVICES ARE DEGRADED

Isolated deployment	Pre-computed summary	Multi-AZ replicas	Local token validation	Local policy decisions	Audit via outbox
bulkhead with reserved capacity	projection, no joins at read time	+ DR region serving reads (active)	cached IdP signing keys	OPA sidecar, cached bundles	no dependency on the audit pipeline

Who can break the glass?
Verified practitioners holding the emergency_access entitlement (emergency medicine, on-call, EMS), granted by the MedX medical lead and reviewed quarterly. Patients may opt out where the law allows it.

Encryption in transit & at rest

Encryption in Transit & at Rest

High-priority requirement H1 · every hop encrypted · two independent layers at rest · keys generated and held in HSM-backed KMS

IN TRANSIT — no plaintext hop, inside or outside the platform

Patient / doctor app	TLS 1.3	Edge (WAF · API Gateway)

HSTS · modern AEAD ciphers only · certificate pinning in mobile apps

Edge	mTLS	Microservices

Service mesh · SPIFFE workload identities · certificates rotated every 24 h

Microservices	TLS (verify-full)	Databases · Kafka · Redis

Dynamic, short-lived database credentials issued by Vault

Patient ⇄ doctor	DTLS-SRTP + E2EE	SFU media node

SRTP is mandatory in WebRTC · end-to-end SFrame layer when both clients support it

Pharmacy systems	mTLS + OAuth 2.0	Partner API

Client-certificate-bound tokens · outbound webhooks signed (HMAC-SHA256)

Microservices	TLS 1.2+	External providers

Certificate validation · no health data in payloads (SMS, e-mail, calendars)

Primary region	TLS + KMS	DR region

Replication streams encrypted in transit and re-encrypted at rest

AT REST — ENVELOPE ENCRYPTION

HSM — FIPS 140-3 level 3

Root keys in HSM
generated in hardware · never leave it · quorum-controlled

KEK (in KMS, no export)	Records KEK per service · env · class	Documents KEK rotated yearly	Consultation KEK every use logged
	wraps	wraps	wraps
DEK (AES-256-GCM)	DEK per patient clinical data	DEK per file documents	DEK per consultation chat messages
	encrypts	encrypts	encrypts
DATA (ciphertext only)	Sensitive FHIR fields notes · national ID	Medical documents object storage	Chat history hot store + archive

Second, independent layer
Disks, databases, object storage, Kafka, Redis and backups are also encrypted (AES-256, KMS keys).

Crypto-shredding
At the end of the retention period, destroying a patient's DEK makes every copy unreadable — including replicas and backups.

Blast radius & performance
One compromised DEK exposes one patient, not the database. Unwrapped DEKs are cached in memory ≤ 5 min to limit KMS calls.